QAYRAWAN INFORMATION SYSTEMS

Cybersecurity Charter and Organizational Structure

ECC Compliance Program · Govern phase

Document ID	QIS-CHR-001
Version	0.1 (Draft)
Date	7 November 2026
Classification	Internal
Prepared by	Naif Alsalem, GRC Lead

Language. This document is issued in Arabic and English. In case of conflict, the Arabic text prevails.

Fictional case study. Qayrawan Information Systems (QIS), its people and its clients are invented for a professional portfolio. Any resemblance to a real organization is unintended. The regulators and frameworks named are real.

Document control

Role	Job title	Name	Status
Owner	GRC Lead	Naif Alsalem	Complete
Reviewer	Chief Technology Officer	Reem Al-Otaibi	Pending
Endorsed by	Cybersecurity Steering Committee	—	Pending
Approver	Chief Executive Officer	Faisal Al-Harbi	Pending

Version history

Version	Date	Author	Change
0.1	7 Nov 2026	Naif Alsalem	First draft for review, translated from the Arabic lead text

Review cycle: Annually, or whenever QIS's organizational structure or regulatory requirements change.

1. Purpose

This charter establishes an independent cybersecurity function at Qayrawan Information Systems, sets its reporting line, authority and responsibilities and its relationship with IT, and governs the work of the Cybersecurity Steering Committee.

It delivers the first program objective in QIS-PRF-001, treats risk R-04 (cybersecurity reporting to the CTO), and responds to subdomains 1-2 (Cybersecurity Management) and 1-4 (Cybersecurity Roles and Responsibilities) of the Essential Cybersecurity Controls.

2. Current state and the case for change

The cybersecurity team currently reports to the CTO, who is also responsible for running systems and meeting project delivery dates. This creates a conflict of interest: the function that delivers technology is the same one that assesses its security and sets its priorities.

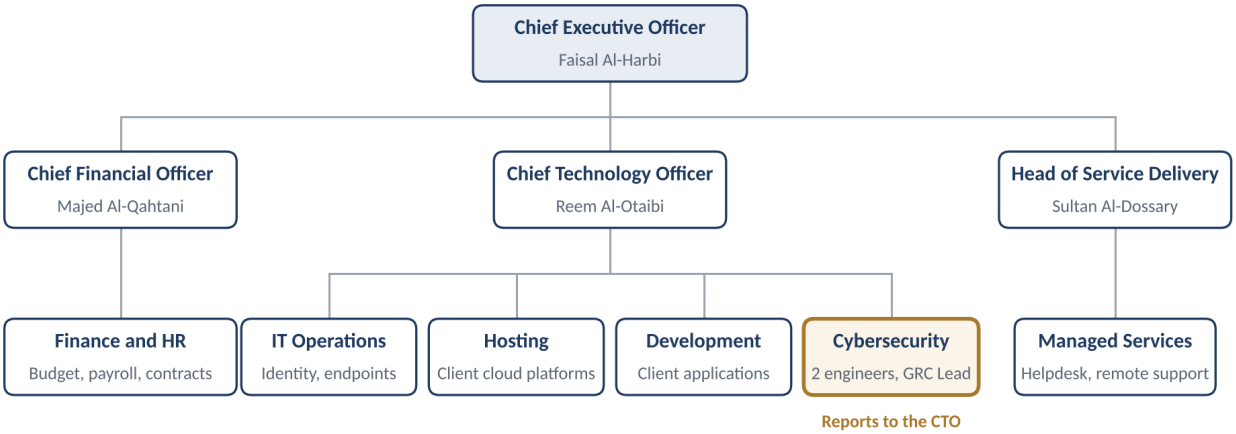


Figure 1. Current structure, October 2026

Problem	Impact
Conflict of interest	Security fixes can be deferred in favour of delivery dates without senior management knowing.
No independent oversight	Cybersecurity risks reach the CEO only through IT.
Limited authority	The team has no authority to stop a change that carries a critical risk.
Control requirements not met	The Essential Cybersecurity Controls expect the cybersecurity function to be independent of IT and to report to the head of the organization.

3. Target structure

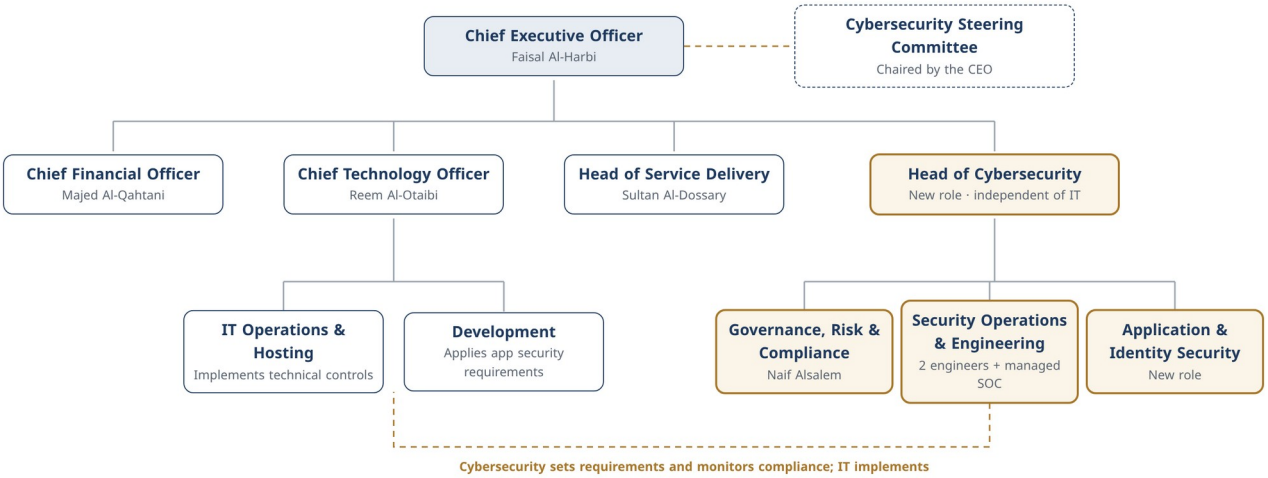


Figure 2. Target structure once the charter is approved

Unit	Staffed by	Main duties	Related ECC subdomains
Head of Cybersecurity	Head of Cybersecurity (new role)	Leads the function, sets strategy, and reports to the CEO and Steering Committee	1-1, 1-2
Governance, Risk and Compliance	Naif Alsalem, GRC Lead	Policies, risk management, compliance assessment, third-party risk, awareness, and personal data protection	1-3, 1-5, 1-7, 1-8, 1-10, 4-1
Security Operations and Engineering	The two current security engineers and the managed SOC	Monitoring, incident response, vulnerability management, and network and endpoint protection	2-3, 2-5, 2-10, 2-12, 2-13
Application and Identity Security	Application security engineer (new role)	Security requirements in development, penetration testing, and identity and privileged access management	1-6, 2-2, 2-11, 2-15

Subdomain numbers follow the numbering used in the risk register and are to be verified against the official ECC-2:2024 text before approval.

4. The charter

4.1 Reporting line and independence

- The cybersecurity function reports directly to the CEO and is organizationally independent of IT.
- The Head of Cybersecurity is appointed by decision of the CEO, and may be removed only by the CEO's decision after informing the Steering Committee.
- The Head of Cybersecurity and the function's supervisory roles are filled by full-time Saudi nationals with cybersecurity experience, as the Essential Cybersecurity Controls require.
- The function has its own budget, approved annually by the CEO.

4.2 Authority

- Access to all systems, logs and documents at QIS relevant to cybersecurity, and at clients within the limits of the contracts.
- Request that any change or release carrying a critical risk, as defined in the risk management methodology, be stopped. Disagreements go to the CEO for a decision within 48 hours.
- Issue detailed security standards and procedures within the approved policies.
- Communicate directly with the CEO, the Steering Committee, and clients' security contacts.

4.3 Responsibilities

- Develop the cybersecurity strategy and roadmap, and track their delivery.
- Write and review policies, and monitor compliance with them.
- Manage cybersecurity risk under QIS-RMM-001, and maintain the risk register.
- Measure compliance with the Essential Cybersecurity Controls and contractual requirements, and prepare evidence packs for clients.

- Lead incident response under QIS-IRP-001.
- Report regularly to the CEO and the Steering Committee.

4.4 Segregation of duties

Activity	Cybersecurity	IT	Independent reviewer
Set security requirements and standards	Responsible	Consulted	—
Implement and run technical controls	Consulted, verifies	Responsible	—
Measure compliance and effectiveness	Responsible	Provides evidence	—
Independent cybersecurity review	Informed	Informed	Responsible
Risk acceptance	Recommends	Consulted	—

The cybersecurity function does not review its own work: the CEO appoints an independent reviewer to review cybersecurity annually.

5. Cybersecurity Steering Committee

Item	Details
Chair	Chief Executive Officer.
Members	CTO, CFO, Head of Service Delivery, and the Head of Cybersecurity (as secretary).
Duties	Endorse the strategy and policies for approval, monitor the risk profile and the KPIs and KRIs, approve and fund treatment plans, and accept high risks.
Meetings	Monthly during the compliance program until April 2027, then quarterly. An emergency meeting may be called for a critical incident.
Quorum	The chair and at least two members, one of them the Head of Cybersecurity.
Minutes	Recorded by the secretary and kept as governance evidence.

6. Transition plan

#	Action	Responsible	Target date
1	Approve this charter	CEO	November 2026
2	Move the security engineers and GRC Lead to report to the CEO, with the GRC Lead as acting head of the function	CEO	December 2026
3	Hold the first Steering Committee meeting under this charter	CEO	December 2026

#	Action	Responsible	Target date
4	Contract a managed SOC (R-03)	Acting head	February 2027
5	Appoint the Head of Cybersecurity	CEO	March 2027
6	Appoint the application and identity security engineer	Head of Cybersecurity	April 2027

7. Function performance indicators

Key performance indicators (KPIs)

Code	Indicator	Target	Frequency
KPI-01	Share of Steering Committee meetings held as scheduled	100%	Quarterly
KPI-02	Share of approved policies that are current (not past their review date)	100%	Quarterly
KPI-03	Share of critical and high risk treatment plans delivered on time	90% or more	Monthly

Key risk indicators (KRIs)

Code	Indicator	Threshold	Frequency
KRI-01	Number of critical-risk changes made without cybersecurity approval	Green: 0 Red: 1 or more	Monthly
KRI-02	Number of critical roles in the function vacant for more than 90 days	Green: 0 Amber: 1 Red: 2 or more	Quarterly

8. References

Reference	Issuer
Essential Cybersecurity Controls (ECC-2:2024), subdomains 1-2 and 1-4	National Cybersecurity Authority
QIS-PRF-001 Company Profile and Program Scope	QIS
QIS-RR-001 Risk Register (R-04)	QIS
QIS-RMM-001 Risk Management Methodology	QIS